LABORATUVAR 6: CRA OLAY SİMÜLASYONU

Aes Group Raptor Ultra

OLAY SENARYOSU (Saat 10:15): AES Raptor Ultra CNC İşleme Merkezi'nin uzaktan bakım / servis hesabında yetkisiz erişim tespit edildi. **AES PLC / OSAI-Syntec** konfigürasyonu (100 m/dk hız sınırları, yazılım limit şalterleri, Vacuboost vakum valf mantığı veya ATC takım değiştirici parametreleri) değişmiş olabilir. Makine o anda 24.000 RPM HSD iş mili ile kesim yapmaya devam ediyor. **Vardiya sorumlusu sizsiniz!**

Altın Kural: *"Resetleyip devam edelim"* düğmesi kanıtı sonsuza dek siler. **Önce emniyet, hemen sonra kanıt!**

Görev: Siber-Fiziksel Olay Müdahale ve CRA Zaman Çizgisi

1. Aşama: Saat 10:15 – İlk 15 Dakika (Acil Müdahale ve Çevreleme)

A) Kimi Ararsınız? (İletişim ve Eskalasyon Zinciri):

1. **Makine Başındaki CNC Operatörü (Dakika 0–1):** Telsiz veya sesli anons ile operatöre derhal **fiziksel tehlike bölgesinden** (ön yükleme alanı, ışık perdesi sınırı ve 100 m/dk hareketli portal köprü güzergahından) uzaklaşması ve güvenli konsol arkasına geçmesi talimatı verilir.
2. **Tesis OT/IT Siber Güvenlik Sorumlusu (SOC / CSIRT) ve Bakım Şefi (Dakika 2–5):** Yetkisiz servis erişiminin ağ üzerinden kesilmesi ve adli bilişim (forensics) kanıt toplama hazırlığı için dahili müdahale ekibi acil koduyla çağrılır.
3. **Fabrika İş Güvenliği (İSG) Uzmanı ve AES Group Ürün Güvenliği (PSIRT) Ekibi (Dakika 5–15):** PLC konfigürasyon değişiminin fiziksel emniyet riski yaratma ihtimali ve **CRA Madde 14** yasal bildirim sürecinin başlatılması için üretici (AES Group Bursa NOSAB Merkez) bilgilendirilir.

B) İlk Üç Eyleminiz Nedir? (Fiziksel Emniyet + Ağ İzolasyonu + Kanıt Koruma):

- **Eylem 1 – Güvenli Duruma Geçiş (Controlled Safe Stop):** PLC konfigürasyonu değişmiş olabileceğinden (örneğin yazılım limit şalterleri kaldırılmış ve 1000 kg kütleli portal şasi dışına çarpacak ya da 5 Bar vakum kilidi iptal edilmiş olabilir) makinenin çalışmaya devam etmesine izin verilmez. Operatöre 21 inç HMI veya **Handterminal Pro+** üzerinden **"Feed Hold (İlerleme Durdurma)"** ve ardından kontrollü **Kategori 1 Güvenli Duruş** komutu verdirilir; HSD iş milinin ≤ 10 sn içinde 0 RPM'e indiği görülür. (*Not: Fiziksel çarpışma anı yoksa ana şalter 400V AC kapatılmaz!*)
- **Eylem 2 – Fiziksel Ağ İzolasyonu (Air-Gap / Kablo Çekme):** Saldırganın bağlantısını kesmek ve içerideki kanıtları silmesini önlemek için, kontrol panosu içindeki OT Güvenlik Duvarı / Switch üzerinden dış dünyaya (Jump Server / VPN – **Conduit C1**) ve fabrika IT ağına (**Conduit C4**) giden **Ethernet (RJ45) kablosu fiziksel olarak çekilir**; pano üzerindeki *Uzaktan Bakım Yetki Anahtarı* **"LOCAL"** konumuna alınarak kilitlenir.
- **Eylem 3 – "DO NOT POWER OFF / RESET" (Gücü Kesme / Resetleme Yasağı):** PLC ve OSAI/Syntec CNC kontrolcünün **RAM (geçici) belleğindeki** aktif ağ oturumları, ARP tabloları ve değiştirilmiş parametre izleri elektriğin kesilmesiyle silineceğinden, makinenin ana

elektriği (30 kW / 400V AC) ve 24V DC kontrol beslemesi **kesinlikle kapatılmaz**; kontrol panosu önüne *"Siber Olay İncelemesi – Dokunmayınız / Resetlemeyiniz"* kilidi (LOTO) asılır.

2. Aşama: İlk 2 Saat (Saat 10:30 – 12:15 | Emniyet, Hesap ve Kanıt Yönetimi)

- **Emniyet Güvende mi? (Safety PLC ve Fiziksel Kilit Doğrulaması):**
  - **Donanımsal İzolasyon Kontrolü:** Raptor Ultra'nın hedef mimarisinde (Lab 2 ve Lab 4) **Safety PLC (OT Safety Zone)**, standart AES PLC'den ayrılmıştır ve aralarında yalnızca tek yönlü (salt-okunur) durum sinyali vardır.
  - **Safety CRC / Checksum Doğrulaması:** Safety PLC'nin üzerindeki kriptografik emniyet imzası (*Safety Signature / CRC*) okunur ve fabrika çıkışlı onaylı değerle aynı olduğu teyit edilir.
  - **Fiziksel Sensör Testi (EN ISO 19085-3):** Makine yüksüz ve güvenli moddayken Dikey/Yatay Işık Perdeleri, Lazer Alan Tarayıcı, Basınç Tamponları ve Acil Durdurma butonları fiziksel olarak tetiklenerek Panasonic servo sürücülerin **STO (Safe Torque Off)** devresini anında kestiği doğrulanır.
- **Hangi Hesap Kapatılır? (Erişim İptali):**
  - Ele geçirilen **"Uzaktan Servis / Bakım Hesabı"** (hem Jump Server / VPN katmanında hem de 21 inç HMI ve AES PLC yerel kullanıcı tablosunda) derhal devre dışı bırakılır (*Disable / Revoke*).
  - Aktif tüm VPN ve uzak masaüstü/SSH token'ları sonlandırılır; makineye tanımlı tüm servis hesaplarının MFA sertifikaları iptal edilir ve PLC üzerindeki fiziksel anahtar **"RUN (Salt-Okunur)"** konumuna alınır.
- **Neyi Korursunuz? (Adli Bilişim Kanıtları – Evidence Preservation):**
  1. **AES PLC ve OSAI/Syntec Bellek Dökümü (Memory & Config Dump):** Mevcut çalışan (ve şüpheli olan) PLC konfigürasyonu, hız limitleri, G-kodu tampon belleği ve register değerleri salt-okunur bir imaj olarak dışa aktarılır ve **SHA-256 hash** değeri alınarak mühürlenir.
  2. **5 Yıllık İzleme Kaydı (Tracing / Audit Log – (AB) 2023/1230 Ek III Madde 1.1.9):** Makine kontrol yazılımına yapılan son müdahalenin zaman damgası, kullanıcı kimliği ve değiştirilen parametre farkları (*diff*) korumaya alınır.
  3. **Jump Server ve OT Firewall Logları:** Saat 10:15'teki girişin kaynak IP adresi, tam oturum video/komut kaydı (*Session Recording*) ve paket yakalama (*PCAP*) dosyaları yazma korumalı (WORM) sunucuya yedeklenir.

3. Aşama: 24 Saat İçinde – CRA Erken Uyarı (Early Warning / Madde 14(2)(a))

11 Eylül 2026 itibarıyla yürürlükte olan **(AB) 2024/2847 Siber Dayanıklılık Yasası (CRA) Madde 14** uyarınca, güvenlik üzerinde etkisi olan ciddi bir olay veya aktif sömürülen zafiyet fark edildiği andan itibaren **en geç 24 saat içinde** ENISA Tek Raporlama Platformu (**SRP**) ve ilgili CSIRT birimine Erken Uyarı geçilmelidir.

24. Saatte Hazır Olması Gereken Zorunlu Bilgiler (Kök neden beklenmez!):

- **Ürün ve Üretici Tanımı:** AES Group (AES Elektronik Makina San. ve Tic. A.Ş.) – *Raptor Ultra CNC İşleme Merkezi* (Model kodu, seri numarası ve OSAI/Syntec + AES PLC bellenim sürümü).

- **Olayın Niteliği ve Aktif Sömürü Durumu:** Saat 10:15'te servis hesabı üzerinden yetkisiz erişim gerçekleştiği, olayın kazara değil **kötü niyetli ve aktif bir müdahale** olduğu bilgisi.
- **Fiziksel Emniyet (Safety) Ön Değerlendirmesi:** PLC parametrelerine müdahale şüphesi bulunduğu, ancak makinenin kontrollü olarak durdurulduğu, ağdan izole edildiği ve herhangi bir operatör yaralanması yaşanmadığı.
- **Sınır Ötesi / Tek Pazar Yayılım Riski:** Aynı servis hesabı mimarisinin veya bellenimin AB pazarındaki (Belçika, Hollanda, İrlanda vb.) diğer Raptor Ultra makinelerinde kullanılıp kullanılmadığı bilgisi.

4. Aşama: 72 Saat İçinde – CRA Olay Bildirimi (Incident Notification / Madde 14(2)(b))

Olayın tespitinden itibaren **en geç 72 saat içinde** teknik analiz derinleştirilerek ENISA/CSIRT'e detaylı bildirim sunulur:

Bildirim Başlığı	Raptor Ultra Teknik Bulgusu ve İçerik	Sorumlu (Kim Ne Yapıyor?)
1. Kök Neden (Root Cause)	Yetkisiz erişimin nasıl gerçekleştiği (Örn: Üçüncü parti taşeron bakım personelinin kimlik bilgilerinin çalınması veya Jump Server üzerinde MFA eksikliği / CVE zafiyeti).	**OT Siber Güvenlik / CSIRT Ekibi** (Log ve PCAP analizi yapar).
2. Siber-Fiziksel Etki (Impact)	Alınan PLC bellek dökümü ile altın imaj (*Golden Image*) karşılaştırılır: Saldırganın 100 m/dk hız sınırını, yazılım limit şalterlerini veya 5 Bar vakum kilidini gerçekten değiştirip değiştirmediği netleştirilir.	**AES Group Otomasyon & Emniyet Mühendisi** (Kod ve parametre farkını çıkarır).
3. Düzeltici Önlem (Mitigation)	Makineye kriptografik imzalı temiz PLC konfigürasyonunun yüklenmesi, tüm parolaların sıfırlanması, MFA zorunluluğu ve EN ISO 13855 duruş süresi ($T \leq 0.308$ sn) doğrulama testinin tekrarlanması.	**Fabrika Bakım Şefi & Müşteri Destek Ekibi** (Saha doğrulamasını yapar).

5. Aşama: 14 Gün (veya Ciddi Olayda 1 Ay) – Nihai Rapor ve Korunacak Kayıtlar

Düzeltici önlemler tamamlandıktan sonra sunulan **Nihai Rapor (Final Report)** ve **(AB) 2023/1230 Makine Tüzüğü Ek III Madde 1.1.9 / 1.2.1** kapsamında piyasa gözetim makamları için **5 yıl boyunca** saklanması zorunlu olan kayıtlar şunlardır:

1. **Adli Bilişim Bütünlük Paketi (Forensic Image):** Olay anında (10:30'da) alınan bozulmamış AES PLC / CNC RAM ve konfigürasyon imajı ile olay öncesi onaylı yedek arasındaki karşılaştırma raporu (*SHA-256 hash* kayıtlarıyla birlikte).
2. **Yazılım Müdahale ve Versiyon İzleme Kaydı (5-Year Tracing Log):** Saat 10:15'teki yetkisiz bağlantıyı, değiştirilen PLC hafıza adreslerini ve sonrasında yüklenen temiz yazılım versiyonunu gösteren silinemez zaman damgalı kayıt defteri.
3. **Ağ ve Erişim Kayıtları (Jump Server / Firewall / SIEM):** Saldırganın giriş yaptığı IP, oturum süresi, çalıştırdığı komutlar ve VPN kimlik doğrulama logları.

4. **Emniyet Yeniden Doğrulama Raporu (Safety Re-validation Test Report):** Temiz kurulum sonrasında yapılan; Safety PLC CRC kontrolü, 24.000 RPM iş mili kilitleme testi (EN ISO 19085-3 Madde 5.3.2), 5 Bar vakum düşümü testi ve EN ISO 13855 ışık perdesi duruş süresi ölçüm tutanağı.
5. **Güncellenmiş Risk Register ve Teknik Dosya (TCF) Kaydı:** Lab 3'teki Risk Register tablosunun bu olaydan çıkarılan derslerle (*Lessons Learned*) güncellenmiş hali.

Denetçi Özeti: Bu iş akışı, vardiya sorumlusunun panikle makineyi resetleyerek adli kanıtları yok etmesini engellemiş; önce operatörü 100 m/dk portal ve 24.000 RPM iş mili tehlikesinden korumuş, ardından CRA Madde 14 (24s/72s/14gün) yasal yükümlülüklerini eksiksiz yerine getirerek **Evidence Pack EP 13** altına kaydedilmiştir.